LIDETA SUB-CITY ADMINISTRATION
Information Technology & Systems Department
Addis Ababa, Ethiopia

OFFICIAL ENGINEERING DOCUMENT

System Architecture and Design Document (SADD)

Lideta Sub-City Official Web Portal & Administrative Platform

Document Code:	LSC-SADD-001
Target Authority:	Information Network Security Administration (INSA) / Hibir
Classification:	Official / Review Release
Release Version:	v1.0.0

Date of Issuance: October 2026

System Architecture and Design Document (SADD)

Lideta Sub-City Official Web Portal & Administrative System

Document Reference: LSC-SADD-001 | Version: 1.0.0

Document Identification

- **Project:** Lideta Sub-City Official Website and Administration Platform
- **Document Code:** LSC-SADD-001
- **Target Organization:** Information Network Security Administration (INSA) / Hibir Review Board
- **Issuing Department:** Lideta Sub-City Administration, IT Development Section
- **Location:** Addis Ababa, Ethiopia
- **Date:** October 2026
- **Status:** Release Candidate / Under Certification Review

Revision History

Version	Date	Authors	Notes & Summary of Changes
0.1	July 15, 2026	IT Dev Team	Initial technical architecture draft
0.9	September 2, 2026	IT Dev Team	Adjusted DB schema and role-segmented admin routes
1.0.0	October 2026	IT Dev Team	Finalized architecture, Plesk MySQL adapter & security headers

---

1. Overview and Engineering Objectives

The Lideta Sub-City administration website is built to handle citizen engagement, local announcements, department directories, recruitment vacancies, and official public grievance tracking for Lideta Sub-City (one of the 10 central sub-cities of Addis Ababa).

The goal for this architecture was to keep things maintainable on our existing infrastructure without introducing unnecessary microservice overhead. We chose a monolithic client-server

setup deployed on our Plesk Linux hosting environment (EthioTelecom IP range).

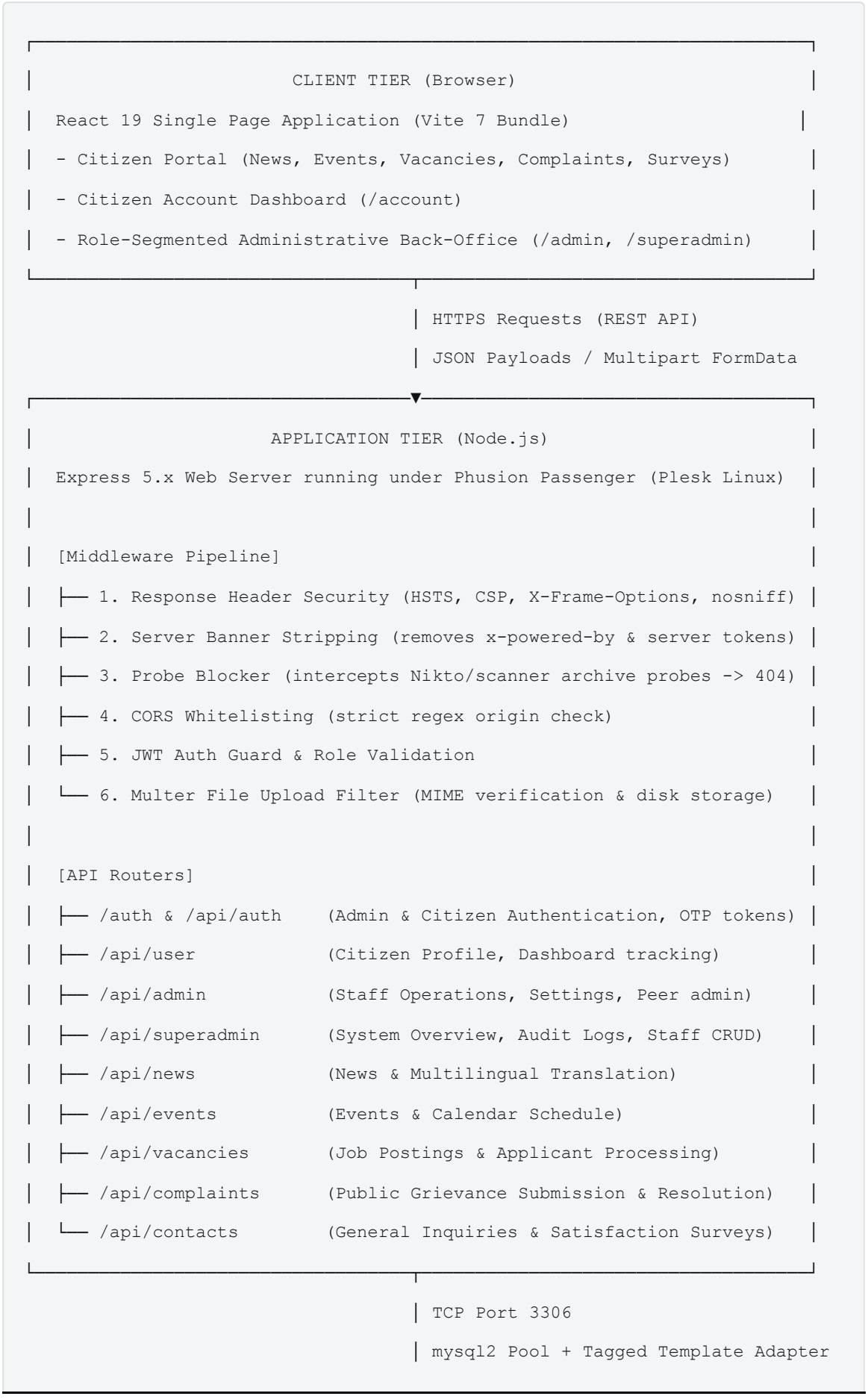
Key Architectural Objectives:

1. **Separation of Concerns:** A dedicated React frontend consuming a clean JSON-based REST API.
2. **Access Security & Segregation:** Role-based access control where staff only see and manage their specific sub-domain (News, Events, Vacancies, or Complaints).
3. **Data Integrity:** Strict input validation, parameterized database queries, and transactional safety for file uploads and user submissions.
4. **Resilience & Scanner Hardening:** Protection against automated scanner probes and standard web vulnerabilities, configured directly at the Express middleware tier.

---

2. High-Level System Architecture

The overall application follows a traditional 3-tier architecture:


CLIENT TIER (Browser)
React 19 Single Page Application (Vite 7 Bundle)
- Citizen Portal (News, Events, Vacancies, Complaints, Surveys)
- Citizen Account Dashboard (/account)
- Role-Segmented Administrative Back-Office (/admin, /superadmin)
HTTPS Requests (REST API)
JSON Payloads / Multipart FormData
APPLICATION TIER (Node.js)
Express 5.x Web Server running under Phusion Passenger (Plesk Linux)
[Middleware Pipeline]
1. Response Header Security (HSTS, CSP, X-Frame-Options, nosniff)
2. Server Banner Stripping (removes x-powered-by & server tokens)
3. Probe Blocker (intercepts Nikto/scanner archive probes -> 404)
4. CORS Whitelisting (strict regex origin check)
5. JWT Auth Guard & Role Validation
6. Multer File Upload Filter (MIME verification & disk storage)
[API Routers]
/auth & /api/auth (Admin & Citizen Authentication, OTP tokens)
/api/user (Citizen Profile, Dashboard tracking)
/api/admin (Staff Operations, Settings, Peer admin)
/api/superadmin (System Overview, Audit Logs, Staff CRUD)
/api/news (News & Multilingual Translation)
/api/events (Events & Calendar Schedule)
/api/vacancies (Job Postings & Applicant Processing)
/api/complaints (Public Grievance Submission & Resolution)
/api/contacts (General Inquiries & Satisfaction Surveys)
TCP Port 3306
mysql2 Pool + Tagged Template Adapter

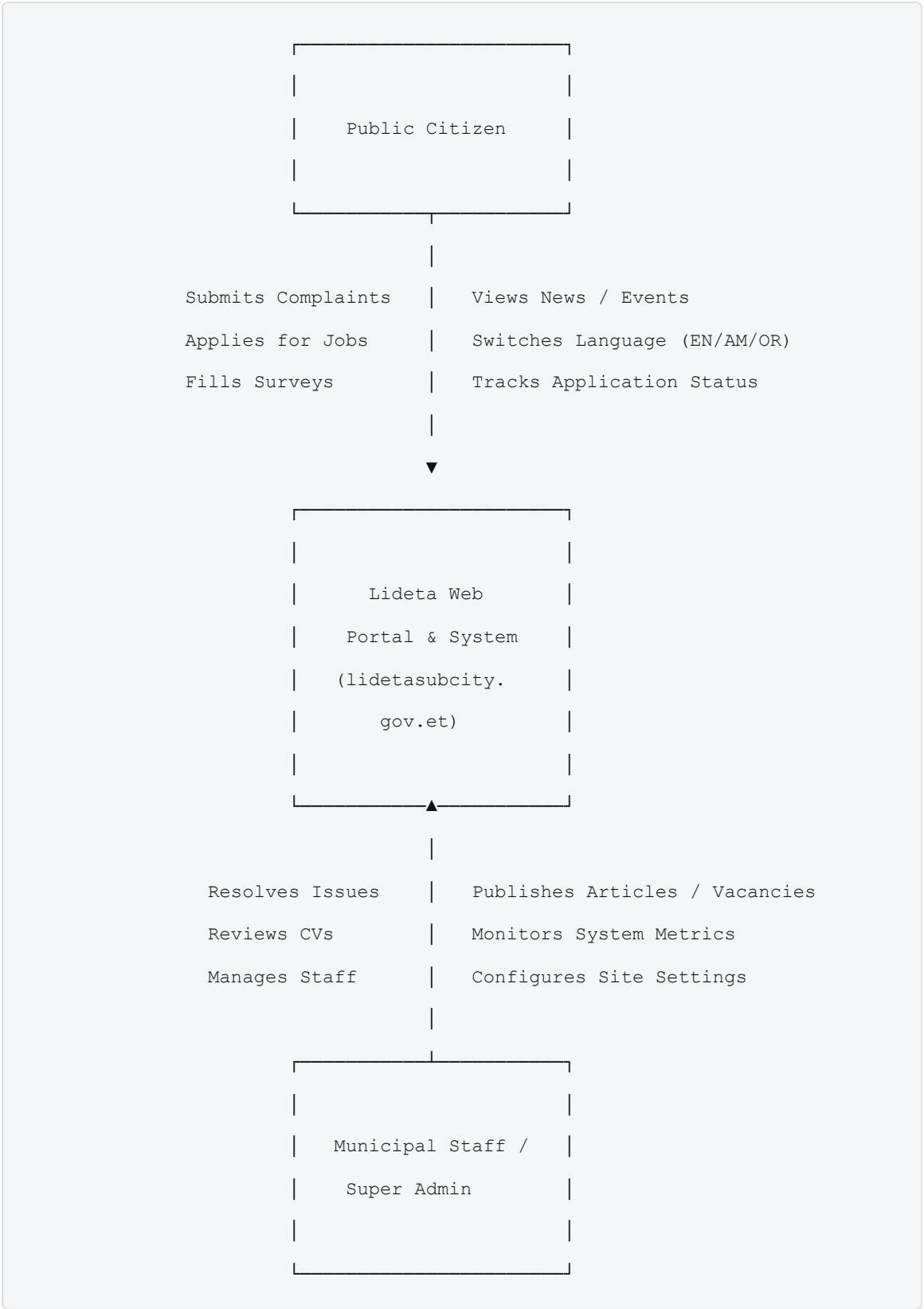
```
┌──────────────────────────────────────▼──────────────────────────────────────┐
│                          DATA TIER (MySQL 8.0)                              │
│  Plesk MySQL Engine (Internal Subnet IP: 10.180.50.142)                     │
│  - Database: lideta_db (InnoDB, utf8mb4 collation)                          │
│  - 14 Persistent Relational Tables                                          │
│  - Transactional consistency for Applications and Complaint tracking        │
└─────────────────────────────────────────────────────────────────────────────┘
```

> ***Developer Note on Hosting Environment:*** *The production server runs on Plesk Obsidian with Node.js managed via Phusion Passenger. Because Passenger maps the incoming web traffic through Nginx to an internal listening socket or assigned port (`process.env.PORT`), the root `app.js` acts as the Passenger entrypoint and invokes `server/server.js`.*

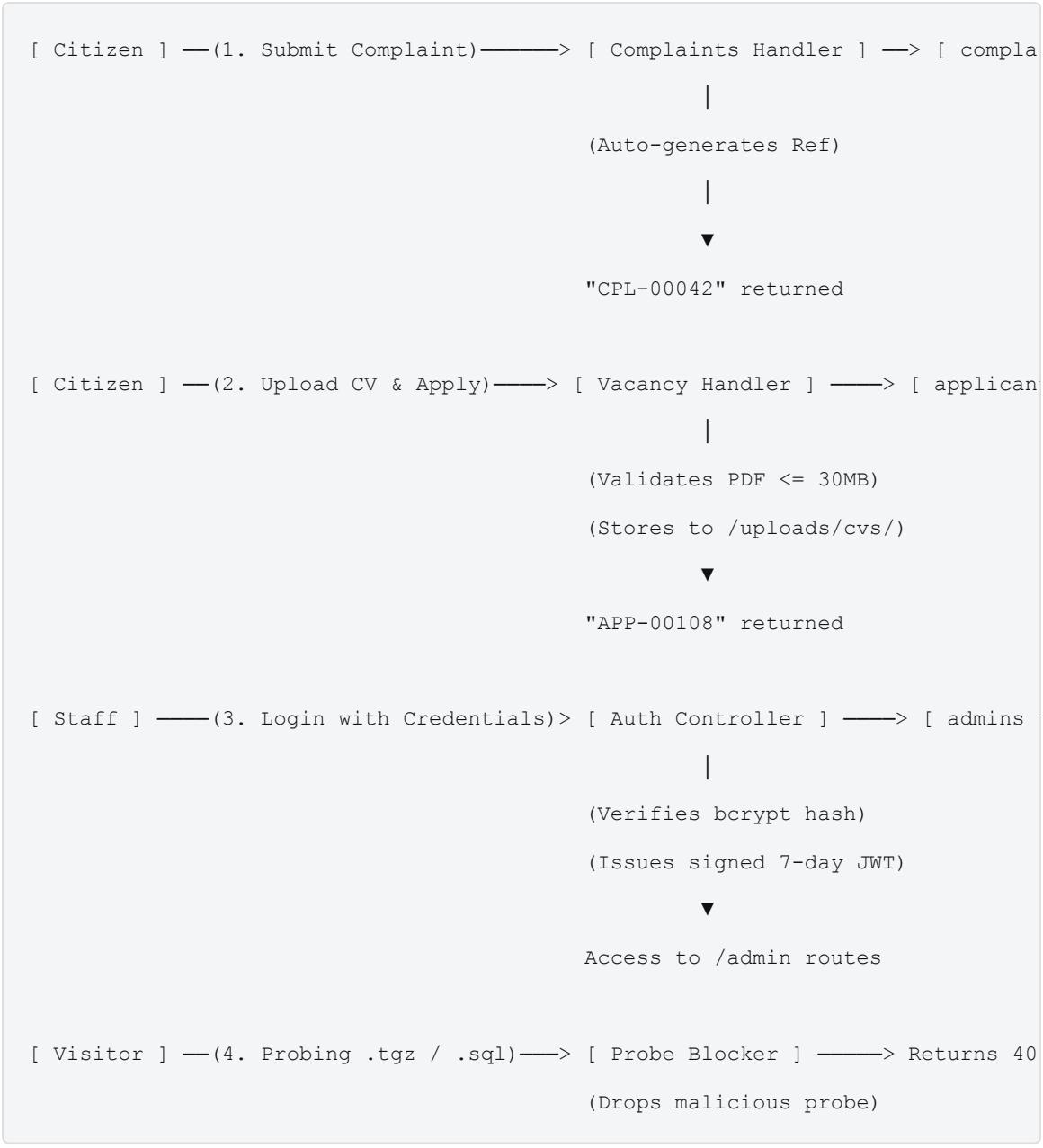
---

3. Data Flow Architecture

3.1 DFD Level 0: Context Diagram



3.2 DFD Level 1: Functional Subsystems



---

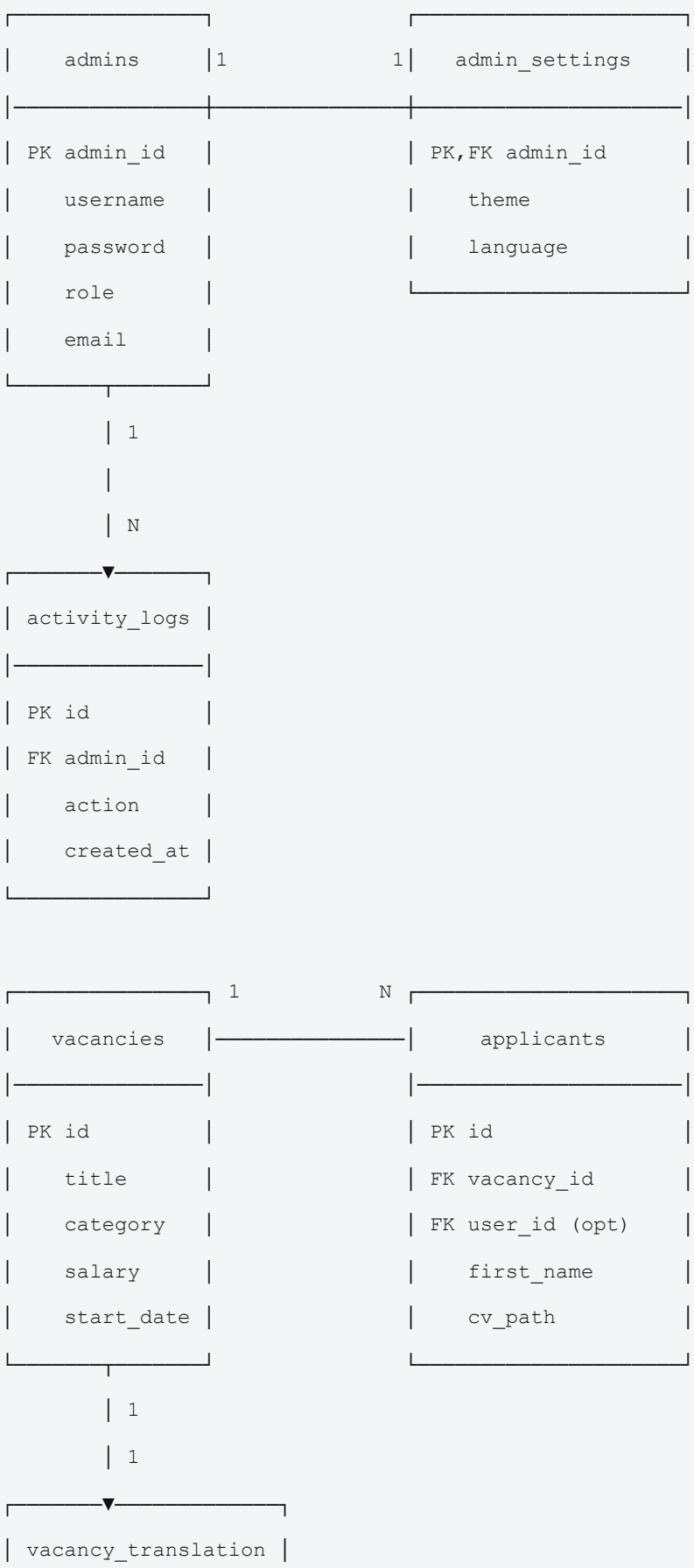
4. Database Design & Schema Architecture

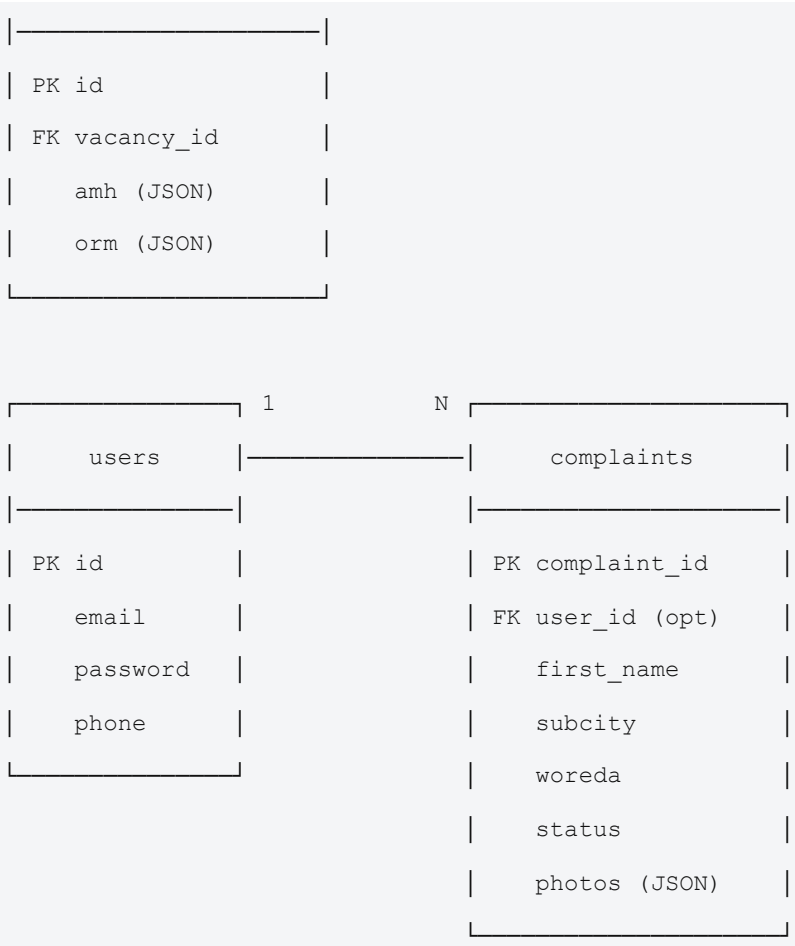
All application data is stored in MySQL 8.0 under the `lideta_db` database using InnoDB engine for referential integrity.

4.1 Schema Overview & Table Summary

Table Name	Primary Key	Description
`admins`	`admin_id` (varchar)	Staff accounts with specific assigned roles
`adminsettings`	`adminid` (varchar)	Admin UI preferences (theme, font size, language)
`activity_logs`	`id` (int auto)	Audit log recording admin actions
`users`	`id` (int auto)	Registered citizen accounts
`otp_tokens`	`id` (int auto)	Single-use 6-digit OTP codes with purpose and expiry
`complaints`	`complaint_id` (int auto)	Public complaints filed by citizens
`vacancies`	`id` (int auto)	Job vacancy announcements
`vacancy_translation`	`id` (int auto)	Amharic and Afaan Oromoo translations for vacancies
`applicants`	`id` (int auto)	Candidate job applications and CV file paths
`news`	`id` (int auto)	Published news articles
`news_translation`	`id` (int auto)	Amharic and Afaan Oromoo translations for news
`events`	`events_id` (int auto)	Upcoming and past sub-city events
`events_translation`	`id` (int auto)	Amharic and Afaan Oromoo translations for events
`contacts`	`id` (int auto)	General inquiries submitted through contact form
`service_satisfaction`	`id` (int auto)	Likert-scale feedback survey responses

4.2 Entity-Relationship (ER) Structure


admins
PK admin_id
username
password
role
email
1
1
admin_settings
PK,FK admin_id
theme
language
1
N
activity_logs
PK id
FK admin_id
action
created_at
vacancies
PK id
title
category
salary
start_date
1
N
applicants
PK id
FK vacancy_id
FK user_id (opt)
first_name
cv_path
1
1
vacancy_translation



> ***Dev Note on MySQL Adapter Translation:*** *The codebase was originally authored using tagged template syntax. To avoid rewriting hundreds of query statements when deploying on Plesk MySQL, we created a specialized adapter (`server/con/mysqlAdapter.js`). It automatically:*
>
> - *Maps `INTERVAL '30 days'` to `INTERVAL 30 DAY`*
> - *Strips Postgres `::jsonb` typecasts*
> - *Converts `TOCHAR(d, 'Mon DD, YYYY')` to MySQL `DATEFORMAT(d, '%b %d, %Y')`*
> - *Serializes JavaScript objects and arrays to JSON strings when binding parameters*
> - *Translates queries to use parameterized prepared statements (`?` placeholders)*

---

5. Security & Protection Architecture

5.1 Security Pipeline Layering

Every HTTP request sent to the server passes through an ordered defensive middleware stack before hitting any route controller:

1. **`app.disable('x-powered-by')`**: Prevents Express from advertising framework identity.
2. **`stripServerHeaders`**: Removes `Server`, `X-Powered-By`, and `X-Passenger-Version` banners so attackers cannot fingerprint the hosting stack.
3. **`securityHeaders`**: Sets baseline modern browser defense headers:

- `X-Frame-Options: SAMEORIGIN` (prevents Clickjacking)
- `Strict-Transport-Security: max-age=31536000; includeSubDomains; preload` (enforces HTTPS)
- `X-Content-Type-Options: nosniff` (stops MIME sniffing)
- `Referrer-Policy: strict-origin-when-cross-origin`
- `Permissions-Policy: camera=(), microphone=(), geolocation=()`
- `Content-Security-Policy`: Restricts scripts and styles to `'self'` and explicitly whitelisted domains (Google Fonts, Google Maps embed for the sub-city location map).

1. **`probeBlocker`**: A custom regex filter that checks incoming paths. If a bot or scanner attempts to request known backup files, certificate keys, dotfiles, or server scripts (`.tgz`, `.tar`, `.sql`, `.cer`, `.pem`, `.env`, `.git`, `.php`), the request is immediately terminated with `404 Not Found` and `Cache-Control: no-store`. This prevents our React SPA wildcard fallback from returning `200 OK` HTML on nonexistent files.
2. **`corsMiddleware`**: Restricts API calls to official sub-city domains (`https://lidetasubcity.gov.et`, `https://www.lidetasubcity.gov.et`) using exact regex matching rather than loose substring checks.

5.2 Authentication & Cryptographic Standards

- **Passwords:** All passwords are salted and hashed using `bcryptjs` with 10 salt rounds. Plaintext passwords are never stored or printed in logs.
- **JWT Tokens:** Generated using `jsonwebtoken` with HMAC-SHA256 and signed via a 256-bit secret stored in server environment variables (`JWT_SECRET`).
- Staff tokens expire in **7 days**.

- Citizen tokens expire in **30 days**.
- **OTP System:** Single-use 6-digit numeric tokens stored in the `otptokens` *table. Every OTP is bound to a specific* `purpose` *(*`2fa`login, `verify`*email, or* `reset`password) and carries a 10-minute expiration timestamp. Once verified, the token row is flagged `used = TRUE` to prevent replay attacks.

---

6. Storage & Upload Architecture

All media uploaded through the portal is saved to structured directories on the local filesystem under `client/public/uploads/`:

- `/uploads/photos/` — News headers, event banners, and citizen complaint photo attachments.
- `/uploads/videos/` — Citizen complaint video evidence.
- `/uploads/audios/` — Voice complaint audio recordings.
- `/uploads/cvs/` — Candidate Curriculum Vitae files (strictly validated as PDF, capped at 30 MB).
- `/uploads/admin_profiles/` — Staff avatar photos.

Files are renamed at upload time using a clean alphanumeric sanitizer plus a timestamp and cryptographically random suffix (`filename-1729000000-839201923.ext`), preventing path traversal and name collisions.

---

7. Operational Roles and Privilege Matrix

Route Group	Allowed Roles	Description
`/superadmin/*`	`superadmin` only	Full administrative oversight, staff account creation/deletion
`/admin/news`	`admin`, `news_admin`	Create, edit, and publish news articles and translations
`/admin/events`	`admin`, `event_admin`	Create, edit, and update event schedules
`/admin/vacancy`	`admin`, `vacancy_admin`	Post vacancies and review submitted applicant CVs
`/admin/complaints`	`admin`, `complaint_admin`	Review complaints, change status, submit administrative response
`/account/*`	Registered Citizen	Track personal complaints and submitted job applications
`/api/*` (Public)	Anyone	Read public content, submit complaints, submit inquiries

8. Summary for INSA / Hibir Compliance

This architecture satisfies the national standards for government web portals:

- Secure coding practices and full parameterization across all SQL endpoints.
- Role-based separation of administrative duties.
- Modern security header enforcement across all endpoints.
- Proper handling of public data vs confidential citizen submissions.

Document finalized by Lideta Sub-City Administration IT Section for INSA submission.